

FIXPROOF

Evidence that changed the review

A frozen primary study, later supplemental evidence, and bounded human decisions

Python orchestrator | JavaScript/Express fixtures | XSS, SQLi, traversal

1. Research question and bounded scope

What this benchmark measures and what it does not.

RESEARCH QUESTION

Can FixProof identify failed or behavior-changing patches that SAST alone could classify as successful?

Study Limit

Results describe three controlled Express applications. They do not estimate performance on production software.

Three fixtures

- Reflected XSS
- SQL injection
- Path traversal

Controlled model setup

- gpt-5.2
- Prompt template v1.0
- Model could not run tools/tests
- 5 initial model calls per fixture (15 total)

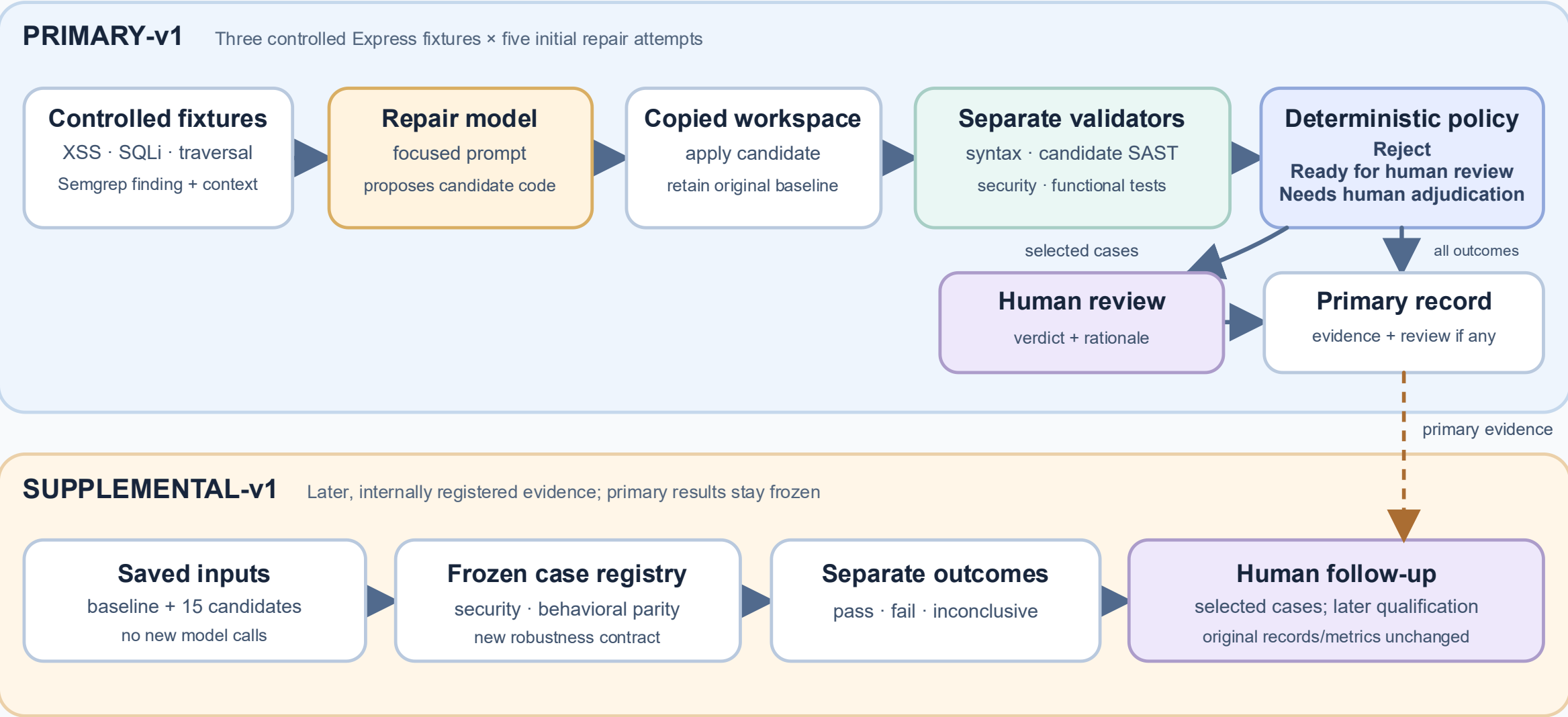
Separated roles

- Model proposes code
- Validators record evidence
- Policy routes the result
- Humans review selected cases

The 15 calls are repeated repairs of three applications, not 15 independent applications.

FIXPROOF | Evidence-first repair workflow

Python orchestrates: the model proposes code; separate checks, policy, and reviewers assess it.



No automatic approval or deployment. Copied workspaces protect study inputs; they are not security sandboxes.

2. Frozen primary-v1 study

Five initial calls per CWE; complete all 15; do not stop early based on outcomes



Primary case	Calls	SAST resolved	Security	Functional	Automated state
Reflected XSS	5	0 / 5	5 / 5	5 / 5	Needs adjudication
SQL injection	5	5 / 5	5 / 5	5 / 5	Ready for review
Path traversal	5	0 / 5	5 / 5	5 / 5	Needs adjudication
Total	15	5 / 15	15 / 15	15 / 15	5 ready 10 adjudicate

0 / 5 resolved means the target scanner finding persisted - not that zero candidates blocked the tested attacks.

3. Supplemental-v1: later, predefined evidence

Same saved candidates | baseline gates first | no new model calls | primary metrics stay frozen



Category	Observations	Pass	Fail	Inconclusive	Interpretation
Security	60	55	0	5	Symlink unavailable
Behavioral parity	45	40	5	0	Observable changes
Robustness	35	25	10	0	New input contracts
Total	140	120	15	5	Mixed categories

Denominators: 12 security x 5 = 60 | 9 parity x 5 = 45 | 7 robustness x 5 = 35

Do not pool these into one "security success rate."

4. Evidence demo: follow one candidate chain

Open the public evidence first; keep raw artifacts as technical backup

- 1 Frozen plan** Five calls per CWE; all 15 completed
- 2 Primary result** Target SAST finding persisted; runtime suites passed
- 3 Candidate patches** String(value) vs String(value ?? "")
- 4 Frozen case result** XSS-P01: undefined (pass) vs blank (fail)
- 5 Later decision** XSS 04: reject candidate for parity

OPEN BEFORE RECORDING

```
fixproof.netlify.app  
  filter: Reflected XSS  
  open: XSS 04
```

Where tests ran:
 saved candidate app/app.js
 localhost (127.0.0.1)
 disposable workspace copy

Raw evidence backup:
 candidate.patch
 supplemental result.json
 follow-up result.json

The public site is a sanitized view of saved evidence; it does not replay historical model calls or tests.

5. XSS 03 versus XSS 04

Both blocked the registered XSS attacks; one changed missing-input behavior

XSS 03

PATCH

String(value)

SAVED XSS-P01 OBSERVATION

```
"body": "<h1>Hello undefined</h1>"  
"status": "pass"
```

Registered supplement: 9 pass | parity 5/5

XSS 04

PATCH

String(value ?? "")

SAVED XSS-P01 OBSERVATION

```
"body": "<h1>Hello </h1>"  
"status": "fail"
```

Registered supplement: 8 pass | 1 parity fail

Both supplemental security: 3/3 pass. XSS 04 was later rejected for parity, not continued exploitability.

6. Human judgment and next steps

Later records qualify the evidence; they never overwrite primary-v1

10 original reviews

7 accept | 3 request more testing

14 later records

5 reject | 5 bounded accept | 4 request

0 overwritten

primary records and metrics stay frozen

LIMITS TO SAY OUT LOUD

- One application per CWE
- 15 calls are not 15 unique patches; SQLi has one source
- PATH-S06 remains inconclusive on Windows
- SQLi target comparison used a labeled controlled rule
- No production-readiness or broad success-rate claim

PROGRESS REPORT 4 NEXT STEPS

- Oct. 11: summarize Video III feedback
- Freeze any new test plan before execution
- Attempt PATH-S06 on a symlink-capable system
- Verify controls, failure handling, and reproduction
- Oct. 18: submit Report 4 with updated limitations

Feedback: Which next step would increase your confidence more: testing FixProof on another vulnerable app, or completing the path-traversal test that Windows could not run?

BACKUP | If asked about SQLi or traversal

Skip during the main recording unless the course format allows extra detail

SQLi 01-05

Primary target SAST: 5/5 resolved

Primary security and functional suites: all 5 candidates passed

Supplement per candidate:

- Security 3/3
- Parity 2/2
- Robustness 2/3

SQL-R01: repeated usernames returned HTTP 200 [] instead of registered HTTP 400.

Human result: bounded accept; failure remains recorded.

Traversal 02-05

Primary target SAST: 0/5 resolved

Primary security and functional suites: all 5 candidates passed

Supplement:

- Five executable security cases pass per candidate
- PATH-S06 symlink case remains inconclusive
- Traversal 03 fails R01-R03
- Traversal 05 fails R03

Human result: request more testing; no symlink-safety claim.

Full matrices and rationales: [Video-III-15-candidate-evidence-appendix.pdf](#)